Conception et mise en place d'un système de détection et de réponse aux attaques ransomware dans un environnement contrôlé

Codjo Fréjus Loïc SANGRONIO

Licence Informatique | Option Sécurité Informatique

24 juin 2026

Encadreur :
Ing. Guy KPEDJO

Sommaire

1. Introduction Générale
2. Revue de littérature
3. Analyse et Conception
4. Réalisation et Résultats
5. Conclusion et Perspectives

PARTIE

01

Introduction Générale

Introduction Générale : Contexte

Contexte

L'évolution rapide du numérique expose les organisations aux ransomwares : des logiciels malveillants qui rendent les données inaccessibles puis exigent une rançon.

- **+73 %** d'attaques signalées en 2023 *(ENISA)*
- Délai moyen de détection **sans outil dédié : 21 jours**
- Coût moyen par attaque : $>$ **1 million de dollars**
- Cibles : PME, hôpitaux, administrations, universités

Objectif général

Concevoir et mettre en œuvre un **système de détection et de réponse aux attaques ransomware** basé sur la surveillance comportementale des fichiers et des processus, avec une console de supervision traçable.

Problématique

Constat

Les antivirus classiques détectent les malwares **connus par leur empreinte**. Face aux variantes nouvelles, ils sont aveugles. Sans outil dédié : **21 jours** en moyenne avant détection — les dommages sont souvent irréversibles.

Problème identifié

Aucune solution open-source, **démontrable en conditions réelles**, n'existe pour la détection comportementale multi-plateforme des ransomwares avec contrôle humain.

Défi #1

Variantes inconnues contournent les antivirus par signatures

Défi #2

Parc hétérogène (Windows, Linux, macOS) à surveiller

Défi #3

Réponse automatique risquée : contrôle humain indispensable

Objectifs spécifiques

- Surveiller les événements fichiers en temps réel sur les terminaux
- Analyser les comportements et calculer un score de risque configurable
- Générer automatiquement des alertes et des incidents de sécurité
- Proposer et exécuter des actions de protection avec **contrôle humain**
- Protéger l'accès à la console par une double authentification (mot de passe + code temporaire)
- Valider l'ensemble du système sur des scénarios d'attaque représentatifs

PARTIE

02

Revue de littérature

Revue de littérature : Définition et comportements

Définition d'un ransomware

Un ransomware est un logiciel malveillant qui vise à bloquer l'accès à un système ou à des données, souvent par chiffrement, puis à réclamer une rançon à la victime. *(NIST SP 1800-25, CISA)*

Comportements caractéristiques (détectables avant les dommages irréversibles)

- Renommage massif de fichiers avec une extension suspecte (`.locked`, `.enc`, `.crypt`...)
- Apparition d'une note de rançon (`HOW_TO_DECRYPT.txt`)
- Suppression des sauvegardes automatiques du système (points de restauration)
- Détournement d'outils système légitimes pour dissimuler l'attaque
- Suppression massive de fichiers, communications réseau inhabituelles

Ces signaux constituent la base de la **détection comportementale**.

Revue de littérature : Solutions existantes

Solutions existantes

- **Antivirus** : détection par empreintes connues (ClamAV, Windows Defender)
- **SIEM** (centralisation des journaux d'activité) : collecte sans analyse comportementale
- **EDR** (surveillance avancée des terminaux) : CrowdStrike, SentinelOne, Defender XDR

Limites des solutions existantes

- ✖ Contournables par variantes nouvelles, obfuscation ou LOLBins
- ✖ Coût élevé des EDR commerciaux (inaccessibles pour PME, hôpitaux, administrations)
- ✖ Aucun outil open-source comportemental démontrable en conditions réelles

Notre réponse : RansomShield

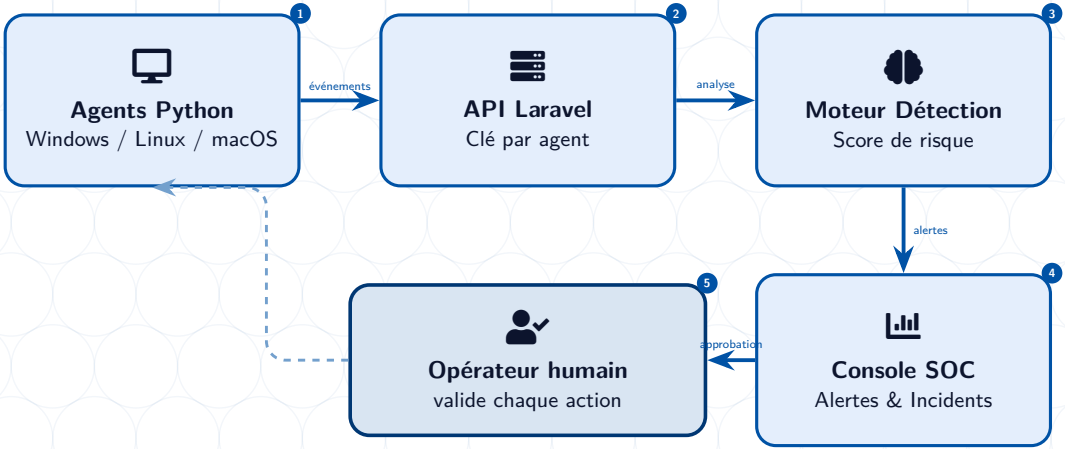
Approche comportementale open-source, multi-plateforme, démontrable sur machines virtuelles réelles, avec **contrôle humain à chaque étape**.

PARTIE

03

Analyse et Conception

Architecture générale de RansomShield



Aucune action automatique : l'opérateur valide avant chaque exécution

Les quatre composants du système

Agent de surveillance

Observe en temps réel les activités fichiers sur chaque terminal. Les événements sont **conservés localement** : rien n'est perdu même en cas de coupure réseau. Démarrage automatique au lancement.

Découverte réseau

Détecte automatiquement toutes les 5 minutes les nouvelles machines. Aucune n'est intégrée au système sans **accord explicite de l'administrateur**.

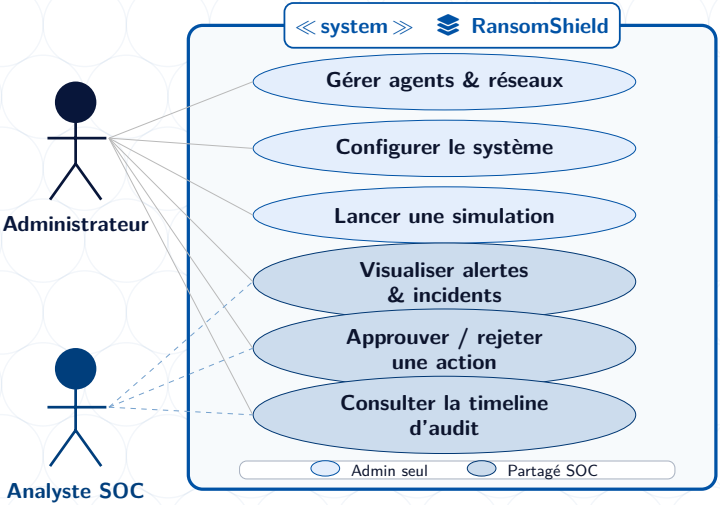
Console de supervision

Tableau de bord actualisé en temps réel. Alertes, incidents, historique des décisions, file d'approbation. Notifications simultanées : web, e-mail, son et webhook.

Simulateur d'attaques

5 scénarios rejoués sans aucun malware réel, jusqu'à **22 événements**. Chaque test est clairement identifié et nettoyable après démonstration.

Diagramme de cas d'utilisation



PARTIE

04

Réalisation et Résultats

Choix techniques

Backend & Base de données

- **Laravel 11** / PHP 8.3
- **MySQL 8.0** (Eloquent ORM)
- API REST sécurisée (clé per-agent)

Frontend

- **Blade** (templates Laravel)
- **Chart.js** (intégré local)
- AJAX toutes les 30 s

Agent de surveillance

- **Python 3.10**
- **Watchdog** (inotify Linux)
- **SQLite** (file locale offline)
- psutil (processus)

Infrastructure de test

- 3 VMs **KVM/libvirt**
- Réseau `10.20.0.0/24`
- **2FA TOTP** RFC 6238
- Token usage unique (enrôlement)

Agent Python et moteur de détection

Fonctionnement de l'agent

1. Démarrage et configuration automatique
2. Enrôlement sécurisé (jeton à usage unique)
3. Surveillance en temps réel des dossiers
4. Événements conservés localement
5. Transmission sécurisée au serveur central
6. Signal de vie toutes les **30 secondes**

Installation en une seule commande depuis la console

Scoring comportemental

Signal détecté	Score
Extension suspecte (`.locked`)	+80
Note de rançon créée	+55
Suppression des sauvegardes système	+60
Outil système détourné	+45
Suppression massive fichiers	+50

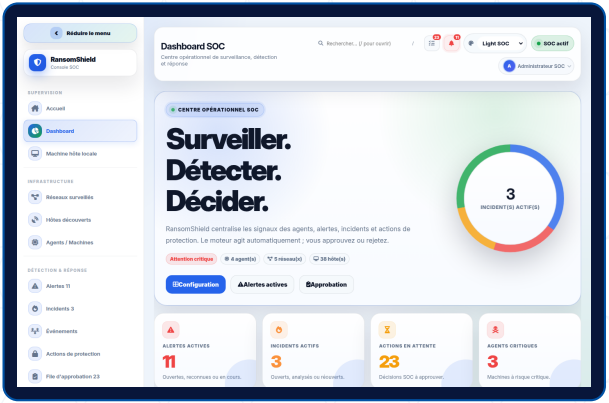
Score < 30	**Normal**
30 à 59	**Suspect**
60 à 99	**Élevé**
≥ 100	**Critique**

Alerte + incident créés automatiquement en < 5 s

Console SOC (Centre opérationnel de sécurité)

Pages de la console

- Tableau de bord
- Agents (état, heartbeat)
- Alertes (score, signaux)
- Incidents
- Timeline d'audit
- File d'approbation
- Règles (CRUD live)
- Recherche globale
- Paramètres système



Mise à jour AJAX toutes les 30 s · Web · E-mail SMTP · Son · Webhook

Tests de validation et résultats

5 scénarios d'attaque testés

Scénario	Évts	Résultat
Chiffrement basique	7	✓
Kill chain complète	22	✓
Chiffrement massif	18	✓
Exfiltration données	8	✓
LOLBins suspects	5	✓

3 VMs KVM | réseau 10.20.0.0/24

Résultats obtenus

- ✓ Détection en $<$ **5 secondes** (tous scénarios)
- ✓ Aucun événement perdu (file SQLite)
- ✓ Pipeline complet validé bout en bout
- ✓ Rollback isolation réseau fonctionnel
- ✓ 2FA TOTP et API sécurisée (per-agent)

Limite identifiée

Tests conduits sur Linux uniquement. Un attaquant ralentissant son rythme réduit la visibilité.

Démonstration Live

PARTIE

05

Conclusion et Perspectives

Conclusion et Perspectives

Conclusion

RansomShield est une solution opérationnelle couvrant l'ensemble du cycle de traitement d'un incident : **collecte** → **analyse** → **alerte** → **réponse** → **audit**.

- ✔ Agent Python multi-plateforme : installation en une commande
- ✔ Console SOC : simulation, 4 canaux de notification, rapports PDF, double auth.
- ✔ Moteur de détection : scoring configurable, règles personnalisables, $< 5\,\mathrm{s}$
- ✔ Environnement contrôlé : aucun vrai malware déployé

Perspectives d'évolution

- **HTTPS** : chiffrement TLS en production
- **RBAC** (droits par rôle) : profils distincts — administrateur et analyste
- **Machine Learning** : détection des anomalies par apprentissage automatique
- **MITRE ATT&CK** (référentiel mondial des attaques) : couverture et alignement
- **Intégration SIEM** (journaux centralisés) : export vers Splunk / ELK Stack

Merci pour votre attention

Codjo Fréjus Loïc SANGRONIO

Licence Informatique — Option Sécurité Informatique | IFRI-UAC